

CASCADE CIVIC SYSTEMS, INC. — SECURITY CONTROLS TI

GrantBridge Platform (SaaS) | FedRAMP Moderate Baseline | NIST SP 800-53 Rev. 5 | Sample GRC por

Control ID	Control Family	Control Name	Baseline	Implementation Status
AC-2	Access Control	Account Management	Moderate	Implemented
AC-2(1)	Access Control	Automated System Account Management	Moderate	Implemented
AC-6(9)	Access Control	Log Use of Privileged Functions	Moderate	Partially Implemented
AC-17	Access Control	Remote Access	Moderate	Implemented
AU-2	Audit and Accountability	Event Logging	Moderate	Implemented
AU-6	Audit and Accountability	Audit Record Review, Analysis, and Reporting	Moderate	Partially Implemented
AU-11	Audit and Accountability	Audit Record Retention	Moderate	Implemented
CA-7	Assessment, Authorization, and Monitoring	Continuous Monitoring	Moderate	Partially Implemented
CM-2	Configuration Management	Baseline Configuration	Moderate	Implemented
CM-6	Configuration Management	Configuration Settings	Moderate	Partially Implemented
CM-7	Configuration Management	Least Functionality	Moderate	Implemented
CP-9	Contingency Planning	System Backup	Moderate	Implemented
CP-10	Contingency Planning	System Recovery and Reconstitution	Moderate	Partially Implemented
IA-2(1)	Identification and Authentication	MFA to Privileged Accounts	Moderate	Implemented
IA-5	Identification and Authentication	Authenticator Management	Moderate	Implemented
IR-4	Incident Response	Incident Handling	Moderate	Implemented
IR-6	Incident Response	Incident Reporting	Moderate	Partially Implemented
RA-5	Risk Assessment	Vulnerability Monitoring and Scanning	Moderate	Partially Implemented

SA-11	System and Services Acquisition	Developer Testing and Evaluation	Moderate	Implemented
SC-7	System and Communications Protection	Boundary Protection	Moderate	Implemented
SC-8	System and Communications Protection	Transmission Confidentiality and Integrity	Moderate	Implemented
SC-13	System and Communications Protection	Cryptographic Protection	Moderate	Implemented
SC-28	System and Communications Protection	Protection of Information at Rest	Moderate	Implemented
SI-2	System and Information Integrity	Flaw Remediation	Moderate	Partially Implemented
SI-4	System and Information Integrity	System Monitoring	Moderate	Implemented
PS-3	Personnel Security	Personnel Screening	Moderate	Implemented
AT-2	Awareness and Training	Literacy Training and Awareness	Moderate	Implemented
MP-6	Media Protection	Media Sanitization	Moderate	Inherited
PE-3	Physical and Environmental Protection	Physical Access Control	Moderate	Inherited
PL-2	Planning	System Security and Privacy Plans	Moderate	Implemented

RACEABILITY MATRIX (SCTM)

tfolio artifact — fictional company

Control Origination	Implementation Summary	Assessment Method
Service Provider Corporate	Accounts provisioned via Okta tied to HRIS events; privileged accounts require manager + system owner approval; automated disable at 35 days inactivity.	Examine, Interview
Service Provider Corporate	Okta Lifecycle Management automates provisioning/deprovisioning; API-driven, no manual account creation in production.	Examine, Test
Service Provider System-Specific	Privileged actions logged in CloudTrail and forwarded to SIEM; logging coverage gap identified on legacy reporting subsystem.	Examine, Test
Service Provider Corporate	All remote administrative access requires MFA and traverses a bastion host with session recording; direct SSH from internet is blocked by SCP.	Examine, Test
Service Provider System-Specific	Auditable event list documented and approved; covers authentication, authorization, data access, configuration change, and privilege escalation events.	Examine, Interview
Service Provider System-Specific	SIEM correlation rules deployed; documented weekly review procedure exists but review evidence was inconsistent for a two-month period.	Examine, Interview
Service Provider System-Specific	Audit records retained online for 90 days and in S3 Glacier for 12 months, meeting FedRAMP retention requirements.	Examine
Service Provider System-Specific	ConMon program documented with monthly vulnerability scanning and reporting; monthly deliverable submitted late in two of the last six cycles.	Examine, Interview
Service Provider System-Specific	Infrastructure defined as code (Terraform); AMLs hardened to CIS Level 1 benchmark and version-controlled.	Examine, Test
Service Provider System-Specific	CIS benchmark applied to compute baseline; drift detected on three application servers during assessment sampling.	Test
Service Provider System-Specific	Container images built from minimal base images; unnecessary services and ports disabled by default and enforced via admission controller.	Examine, Test
Service Provider System-Specific	Automated encrypted backups: database PITR (5-min RPO) plus daily full snapshots replicated cross-region.	Examine, Test
Service Provider System-Specific	Recovery procedures documented; full-system recovery has not been exercised within the required annual period.	Examine, Interview
Service Provider Corporate	Phishing-resistant MFA (FIDO2/WebAuthn) enforced for all privileged accounts via Okta policy.	Examine, Test
Service Provider Corporate	Password policy aligned to NIST SP 800-63B; no forced periodic rotation, breached-password screening enabled.	Examine, Test
Service Provider Corporate	Documented IR plan with defined severity tiers; 24x7 on-call rotation; US-CERT reporting procedure defined per FedRAMP requirements.	Examine, Interview
Service Provider Corporate	Internal reporting path defined; the one-hour US-CERT/FedRAMP ISSO notification requirement is documented but has not been exercised in a tabletop.	Examine, Interview
Service Provider System-Specific	Authenticated scanning performed monthly on infrastructure, OS, web, and database layers; several High findings exceeded the 30-day FedRAMP remediation window.	Examine, Test

Service Provider Corporate	SAST and dependency scanning enforced in CI; annual third-party penetration test performed with findings tracked to closure.	Examine
Service Provider System-Specific	Authorization boundary enforced via VPC segmentation, security groups, WAF, and a deny-by-default egress policy; managed interfaces documented in the SSP.	Examine, Test
Service Provider System-Specific	TLS 1.2+ with FIPS 140-3 validated cryptographic modules enforced on all external and internal service-to-service communication.	Examine, Test
Service Provider System-Specific	FIPS 140-3 validated modules used for all cryptographic operations; AWS KMS FIPS endpoints in use.	Examine
Service Provider System-Specific	All data stores encrypted at rest with AES-256 via customer-managed KMS keys with annual rotation.	Examine, Test
Service Provider System-Specific	Patching automated for OS/container layers; remediation SLA missed for a subset of High-severity findings (see RA-5).	Examine, Test
Service Provider System-Specific	IDS/IPS via GuardDuty, host-based monitoring, and file integrity monitoring feeding the SIEM with 24x7 alerting.	Examine, Test
Service Provider Corporate	Background investigations completed for all personnel with system access prior to provisioning; re-screening every five years.	Examine, Interview
Service Provider Corporate	Annual security awareness training with role-based modules for privileged users; completion tracked at 100% for in-scope personnel.	Examine
Inherited from AWS (FedRAMP High P-ATO)	Media sanitization is inherited from the underlying IaaS provider; customer responsibility limited to logical data deletion.	Examine
Inherited from AWS (FedRAMP High P-ATO)	Physical access to data centers is fully inherited from the underlying IaaS provider's authorized environment.	Examine
Service Provider System-Specific	This SSP documents the authorization boundary, control implementations, and system environment; reviewed and updated at least annually.	Examine

Assessment Result	Related POA&M ID
Satisfied	
Satisfied	
Other Than Satisfied	V-003
Satisfied	
Satisfied	
Other Than Satisfied	V-005
Satisfied	
Other Than Satisfied	V-007
Satisfied	
Other Than Satisfied	V-002
Satisfied	
Satisfied	
Other Than Satisfied	V-004
Satisfied	
Satisfied	
Satisfied	
Other Than Satisfied	V-006
Other Than Satisfied	V-001

[illegible]

CONTROL IMPLEMENTATION SUMMARY

Counts derived from the SCTM tab. Full FedRAMP Moderate baseline is 323 controls; this sample documen

Implementation Status	Count	% of Sampled Controls
Implemented	20	66.7%
Partially Implemented	8	26.7%
Inherited	2	6.7%
Planned	0	0.0%
Not Applicable	0	0.0%
TOTAL	30	

Assessment Result

Result	Count	% of Sampled Controls
Satisfied	22	73.3%
Other Than Satisfied	8	26.7%

ts a representative subset.

SCTM — LEGE

Purpose

Implementation Status

Control Origination

Assessment Methods

Assessment Result

Traceability

Scope note

END & METHODOLOGY

The Security Controls Traceability Matrix documents how each NIST SP 800-53 Rev. 5 control in the FedRAMP Moderate is implemented, who is responsible for it, how it was assessed, and whether it passed.

Implemented | Partially Implemented | Planned | Alternative Implementation | Not Applicable | Inherited (from an underlying authorized service provider)

Service Provider Corporate (org-wide control) | Service Provider System-Specific (unique to this system) | Inherited | Custom (Configured/Provided) | Shared

Examine (documentation/artifacts), Interview (personnel), Test (technical validation) — per NIST SP 800-53A

Satisfied = control operating as designed | Other Than Satisfied = deficiency identified, which generates a POA&M item

Every 'Other Than Satisfied' control links to a POA&M ID in the Related POA&M ID column, so a reviewer can trace a control deficiency straight to its remediation plan and due date.

This sample documents 30 representative controls across 15 families. A production FedRAMP Moderate SSP addresses all controls and enhancements.